COMPTIA SECURITY+ SY0-701 | DOMÍNIO 5 · GESTÃO DE PROGRAMA DE SEGURANÇA E GOVERNANÇA (20%)

Security+ 5.4 · Privacy

Mestre CyberSec · **Aula 5.4 — Privacy** (5:21) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Privacidade: legal implications (GDPR, CCPA, LGPD, HIPAA); data responsibilities (owner/controller/processor/custodian); inventory (qual dado tens onde); retention (menor possível; GDpR apaga quando não preciso).

💡 Highlights que a prova CompTIA cobra

- Privacidade: LEIS de proteção de dado pessoal (GDPR/CCPA/LGPD)
- Data minimization: coleta só o NECESSÁRIO; retention: guarda só o tempo legal

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'right to request deletion of your data'=GDPR right to erasure

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 5.4 — Privacy)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Regulamento Geral de Proteção de Dados (GDPR)

Regulamento de privacidade da UE que rege o tratamento de dados pessoais e garante direitos como acesso, correção e eliminação. Exige base legal, minimização e notificação de violações.

⚠️ ***Armadilha CompTIA:*** *Se a questão falar em 'right to request deletion of your data' ou 'right to be forgotten', marque GDPR right to erasure. GDPR se aplica a titulares na UE, independentemente de onde a empresa está.*

• Lei de Privacidade do Consumidor da Califórnia (CCPA)

Lei de privacidade do estado da Califórnia que concede aos consumidores direitos de saber, excluir e optar por não vender suas informações pessoais. Aplica-se a empresas qualificadas que tratam dados de residentes da Califórnia.

⚠️ ***Armadilha CompTIA:*** *CCPA é estadual/EUA-Califórnia e foca direitos do consumidor, incluindo opt-out da venda de dados. Não confunda com GDPR, que é da UE e tem base legal mais ampla.*

• Lei Geral de Proteção de Dados (LGPD)

Lei brasileira de proteção de dados pessoais que rege o tratamento de dados e concede direitos semelhantes ao GDPR. Aplica-se a tratamentos no Brasil ou de indivíduos localizados no Brasil.

⚠️ ***Armadilha CompTIA:*** *LGPD é a lei brasileira, inspirada no GDPR; se a questão citar Brasil ou LGPD, não marque GDPR/CCPA. Também prevê eliminação de dados quando não mais necessários.*

• Lei de Portabilidade e Responsabilidade de Seguro Saúde (HIPAA)

Lei dos EUA que protege a privacidade e a segurança de informações de saúde protegidas (PHI) mantidas por entidades cobertas e associados de negócios. Define salvaguardas administrativas, físicas e técnicas.

⚠️ ***Armadilha CompTIA:*** *HIPAA = dados de saúde/PHI nos EUA. Se a questão mencionar PHI, healthcare, covered entity ou business associate, pense HIPAA, não GDPR/CCPA.*

• Controlador de Dados (N/A)

Entidade que determina as finalidades e os meios do tratamento de dados pessoais. Possui responsabilidade legal primária pela conformidade com leis de privacidade.

⚠️ ***Armadilha CompTIA:*** *Pergunta sobre 'quem decide por que e como os dados são tratados' = Data Controller. Não confunda com Processor, que apenas executa o tratamento em nome do controlador.*

• Operador de Dados (N/A)

Entidade que trata dados pessoais em nome e sob as instruções de um controlador de dados. Geralmente tem obrigações contratuais, mas responsabilidade legal direta menor que o controlador.

⚠️ ***Armadilha CompTIA:*** *Pergunta sobre 'quem processa dados em nome de outra organização' = Data Processor. Owner é accountable; Custodian faz a guarda técnica; Controller define finalidade.*

• Minimização de Dados (N/A)

Princípio de privacidade de coletar e tratar apenas os dados pessoais estritamente necessários para a finalidade declarada. Reduz riscos e é exigido por regulamentos como GDPR e LGPD.

⚠️ ***Armadilha CompTIA:*** *Se a questão pede reduzir coleta ao necessário ou limitar dados ao propósito, marque Data Minimization. É diferente de retenção, que trata por quanto tempo guardar.*

• Retenção de Dados (N/A)

Política e prática de manter dados apenas pelo tempo exigido por lei ou necessidade de negócio, e então excluí-los com segurança. Depende de um inventário de dados para saber quais dados existem e onde.

⚠️ ***Armadilha CompTIA:*** *GDPR storage limitation: guarde pelo menor tempo possível e apague quando não precisar. Data inventory responde 'qual dado tens e onde'; retention define 'por quanto tempo guardar'.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um hospital nos EUA contrata um serviço de faturamento em nuvem para processar informações de saúde eletrônicas protegidas (ePHI). O serviço em nuvem sofre uma violação que afeta registros de pacientes. Sob a HIPAA, qual parte tem a responsabilidade principal de notificar os pacientes afetados?

A) O serviço de faturamento em nuvem, porque armazenou a ePHI

B) O hospital, como entidade coberta

C) Os pacientes, porque são donos de seus dados de saúde

D) O Escritório de Direitos Civis do HHS, porque regula a HIPAA

QUESTÃO 2 · CENÁRIO DE EXAME

Um varejista online na UE quer lançar um programa de fidelidade. A equipe de marketing propõe coletar data de nascimento, endereço residencial, renda e preferências de compra, embora apenas as preferências de compra sejam necessárias para conceder pontos. Qual princípio do GDPR a equipe de privacidade deve aplicar para limitar a coleta?

A) Limitação de armazenamento

B) Minimização de dados

C) Direito de retificação

D) Portabilidade de dados

QUESTÃO 3 · CENÁRIO DE EXAME

Uma empresa com sede na Califórnia recebe uma solicitação verificada de exclusão de um consumidor sob a CCPA. As informações pessoais do consumidor também são mantidas por um provedor de serviços que a empresa usa para análises. O que a empresa deve fazer?

A) Excluir os dados apenas de seus próprios sistemas e ignorar o provedor de serviços

B) Dizer ao consumidor para contatar o provedor de serviços diretamente

C) Instruir o provedor de serviços a excluir as informações pessoais do consumidor

D) Reter os dados porque dados de análise são isentos da CCPA

QUESTÃO 4 · CENÁRIO DE EXAME

Uma empresa brasileira quer transferir dados pessoais de funcionários brasileiros para sua controladora nos Estados Unidos para gestão global de RH. Sob a LGPD, o que a empresa deve garantir antes da transferência?

A) Que os funcionários assinem uma renúncia a todos os direitos de privacidade

B) Que o país receptor tenha leis de privacidade idênticas às do Brasil

C) Que um mecanismo legal de transferência internacional esteja em vigor

D) Que os dados sejam criptografados apenas com AES-256

QUESTÃO 5 · CENÁRIO DE EXAME

Uma empresa de varejo decide por que e como os dados pessoais dos clientes serão processados e firma um acordo de processamento de dados com um fornecedor SaaS que hospeda e gerencia o banco de dados. Sob o GDPR, qual papel o fornecedor SaaS tem?

A) Controlador de dados

B) Operador de dados (processor)

C) Titular dos dados

D) Controlador conjunto

QUESTÃO 6 · CENÁRIO DE EXAME

Uma empresa mantém tickets de suporte ao cliente indefinidamente 'por precaução' para uma possível disputa futura. Uma auditoria de privacidade não encontra prazo de exclusão definido. Qual ação melhor se alinha aos requisitos de retenção de privacidade?

A) Manter todos os registros para sempre para preservar evidências

B) Excluir todos os registros imediatamente sem revisão

C) Definir um cronograma de retenção e excluir ou anonimizar dados quando não forem mais necessários

D) Mover os registros para armazenamento offline e parar de rastreá-los

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa multinacional não consegue responder em quais países armazena dados pessoais de clientes, quais sistemas os processam ou por quanto tempo são mantidos. Qual ação deve ser tomada primeiro para melhorar a conformidade de privacidade?

A) Realizar um inventário de dados e manter registros das atividades de processamento

B) Implantar um novo firewall de aplicação web

C) Criptografar todos os bancos de dados com chaves gerenciadas pelo cliente

D) Nomear imediatamente um encarregado de proteção de dados

QUESTÃO 8 · CENÁRIO DE EXAME

Um funcionário da recepção de um hospital precisa confirmar uma consulta e pede acesso ao histórico médico completo do paciente. O encarregado de privacidade diz que o funcionário deve ver apenas os detalhes da consulta. Qual princípio da HIPAA apoia essa decisão?

A) Mínimo necessário

B) Portabilidade de dados

C) Direito à exclusão

D) Controlador de dados

QUESTÃO 9 · CENÁRIO DE EXAME

Uma empresa sujeita à CCPA vende informações pessoais para parceiros de publicidade. Um consumidor da Califórnia envia uma solicitação verificada de opt-out. O que a empresa deve fazer?

A) Parar de vender as informações pessoais do consumidor

B) Excluir todos os registros do consumidor em 24 horas

C) Fornecer ao consumidor uma cópia de todos os dados vendidos

D) Continuar vendendo, mas rotular os dados como pseudonimizados

QUESTÃO 10 · CENÁRIO DE EXAME

Em uma empresa de serviços financeiros, o departamento de marketing define a finalidade de um banco de dados de clientes e aprova quem pode usá-lo. A equipe de operações de TI realiza backups, aplica controles de acesso e gerencia mídias de armazenamento. Qual papel melhor descreve a equipe de operações de TI?

A) Proprietário dos dados

B) Controlador de dados

C) Operador de dados (processor)

D) Custodiante dos dados

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — O hospital, como entidade coberta

Sob a HIPAA, a entidade coberta é responsável por notificar os indivíduos afetados em caso de violação. Um associado de negócios deve notificar a entidade coberta, mas a entidade coberta geralmente fornece a notificação individual.

Questão 2: Alternativa B — Minimização de dados

A minimização de dados do GDPR exige que os dados pessoais sejam adequados, relevantes e limitados ao necessário para as finalidades declaradas. A limitação de armazenamento trata de por quanto tempo os dados são mantidos, não do que é coletado.

Questão 3: Alternativa C — Instruir o provedor de serviços a excluir as informações pessoais do consumidor

A CCPA exige que a empresa instrua seus provedores de servi��os ou contratados a excluir as informações pessoais do consumidor após uma solicitação verificada de exclusão, salvo se houver exceção legal aplicável.

Questão 4: Alternativa C — Que um mecanismo legal de transferência internacional esteja em vigor

A LGPD permite transferências internacionais somente quando um mecanismo legal se aplica, como decisão de adequação, cláusulas contratuais, normas corporativas globais ou consentimento específico. Criptografia isolada é uma salvaguarda, não um mecanismo autônomo de transferência.

Questão 5: Alternativa B — Operador de dados (processor)

O fornecedor SaaS processa dados pessoais em nome e segundo instruções da empresa de varejo, portanto é um operador de dados (processor). A empresa de varejo determina finalidades e meios, tornando-se a controladora.

Questão 6: Alternativa C — Definir um cronograma de retenção e excluir ou anonimizar dados quando não forem mais necessários

Leis de privacidade como a limitação de armazenamento do GDPR exigem retenção apenas pelo tempo necessário. Um cronograma de retenção equilibra necessidades legais e de negócio com exclusão ou anonimização.

Questão 7: Alternativa A — Realizar um inventário de dados e manter registros das atividades de processamento

Um inventário de dados e registros das atividades de processamento identificam quais dados existem, onde estão, quem os processa e por quanto tempo são retidos. Essa base é necessária antes de selecionar controles de privacidade.

Questão 8: Alternativa A — Mínimo necessário

O princípio do mínimo necessário da HIPAA exige limitar o acesso, uso e divulgação de PHI ao mínimo necessário para a tarefa. O histórico médico completo não é necessário para agendamento de consulta.

Questão 9: Alternativa A — Parar de vender as informações pessoais do consumidor

A CCPA concede ao consumidor o direito de optar por não ter suas informações pessoais vendidas; a empresa deve honrar a solicitação e parar a venda. Exclusão e acesso são direitos diferentes.

Questão 10: Alternativa D — Custodiante dos dados

O custodiante dos dados é responsável pela proteção diária, backup e armazenamento dos dados conforme as políticas do proprietário dos dados. O proprietário define classificação e acesso; o controlador determina as finalidades de processamento.